

2026

Projet Spécialité Cybersécurité



Paul RENSON

[Nom de la société]

23/01/2026

Nom des participants

Darryl Dyvan TCHAPDA

TCHANTCHOU

Noubouossie Kingni Boris Armel

PARTIE 1 : Analyse EBIOS RM complète

Voici l'analyse des risques qu'on a faite chez TechnoSite Industrie. On a utilisé la méthode EBIOS Risk Manager (RM) parce qu'elle collait bien au contexte industriel .

Selon la méthode EBIOS RISK Manager de l'anssi , la première étape consiste à définir le périmètre et les besoins de sécurité .

1.Périmètre du système étudié et Besoin de sécurité (Atelier1)

Le système d'information de TechnoSite Industrie comprends :

- ❖ Zone IT
 - Active Directory
 - ERP
 - Messagerie
 - Postes Utilisateurs
- ❖ Zone OT
 - Automates industriels (PLC Siemens)
 - Robots industriels
 - Capteur IoT
- ❖ Supervision
 - SCADA connecté au cloud
- ❖ Systèmes périphériques
 - Caméras IP
 - Controle d'accès RFID
- ❖ connexion externes
 - VP vers le siège
 - Application web de maintenance distante

Ces éléments forment une architecture IT/OT , un vrai point de faiblesse connu selon les guides AINSI ICS .

Besoin	Description
Disponibilité	Maintenir la production des usines à flot
Intégrité	Comment sécuriser les instructions envoyées aux robots
Confidentialité	Protéger les plans industriels et les données des clients.
Traçabilité	Être capable de trouver et d'étudier une intrusion.

Ces objectifs correspondent aux principes de **confidentialité** , **d'intégrité** et de **disponibilité** (CIA) que l'on retrouve dans les **normes ISO 27001 et ISO 27005** .

1.Source de Risque (Atelier 2)

Selon le guide EBIOS RM et les rapports de cybermenaces de l'ANSSI ,les principales sources de risques sont :

Acteur	Motivation	capacité
Hacker opportuniste	Gain financier(ransomwar e)	Moyenne
Concurrent industriel	Espionnage économique	Elevée
Employé malveillant	revanche	Moyenne
Groupe APT	Espionnage étatique	Très élevé

Les groupes APT ciblent les systèmes industriels critiques , comme indiqué dans les raaports CERT-FR.

1.Scénario stratégique (Atelier 3)

Scénario 1 - Sabotage industriel

Attaque des automates PLC via le réseau OT .

Conséquences:

- Arrêt de la production
- Pertes d'argent
- Risque industriel

Technique associée (MITRE ATT & CK ICS):

- Modification du contrôleur industriel
- Modification de paramètre PLC .

Scénario 2 - Espionnage industriel

Vol de fichier de conception depuis le serveur interne .

Technique :

- Accès par un compte piraté
- Transfert vers un serveur contrôle

Conséquences :

- Perte de propriété intellectuelle .

Scénario 3 - Attaque au Rançongiciel sur le réseau informatique .

Propagation via phishing

Conséquence :

- Chiffrement des serveurs
- L'ERP est hors service , donc impossible de gerer les operations
- Le SCADA est bloqué

Les rapports CERT-FR indiquent que **LockBit** représente un part import des attaques ransomware

Scénario 4 : Entrée non autorisée

Copie d'un badge RFID .

Conséquences:

- Accès aux salles de serveurs
- Installation de virus

Scénario opérationnels (Atelier 4)

Chaîne d'attaque inspirée du modèle MITRE ATT & CK :

Reconnaissance

Techniques :

- Scanner le réseau.
- Chercher les appareils exposés.

Outils :

- Nmap
- Shodan

Résultat :

- ☐ On voit quels services sont accessibles .

1.Intrusion

Méthode possible :

- ❖ Phishing ciblé
- ❖ exploiter une faille web

Outils :

- ❖ Gophish
- ❖ Owasp juice Shop

2.Mouvement latéral

L'attaquant arrive dans le réseau interne .

Techniques :

- Voler les identifiants .
- Exploitation de Active Directory

Outils :

- BloodHound
- Metasploit

Sabotage ou exfiltration

Action possible :

- Modifier les paramètres des automates programmables .
- Crypter des machines
- Voler de données

Persistance

Implantation :

- Porte dérobée (Backdoor)
- Communication avec un serveur c2

3 - Proposition de plan de sécurisation global (technique + organisationnel).

Les recommandations sont basées sur :

- NIST Cybersecurity Framework
- ISO 27005
- ANSSI ICS Security
- Directive NIS2

Sachant que dans notre système il existe plusieurs architecture nous allons présenter les propositions pour la sécurisation de chaque architecture.

1-sécurisation de l'architecture réseau

Segmentation réseau selon **le purdue Model**

- **Segmentation IT | OT | DMZ** : Mettre en place une segmentation stricte afin d'éviter qu'une compromission du réseau bureautique impacte la production.

De ce fait nous recommandons l'architecture suivante:

VLAN IT	DMZ INDUSTRIELLE	VLAN OT	RÉSEAU SÉCURITÉ
Poste utilisateurs	Serveur intermédiaire	Automates PLC	Caméra Ip
ERP	Passerelle SCADA	Robots	Conteole RFID
Messagerie		Capteurs IOT	

A cela nous associons d'autres mesures qui sont les suivantes:

- ❖ Pare Feu Industrielle entre l'architecture IT et OT
- ❖ Interdiction des connections directes reliant IT et PLC

Toutes ces mesures viendront ici empêcher un ransomware IT d'atteindre les automates industriels . cela limite les mouvements latéraux .

2-sécurisation des access

Sachant que pour accéder à chaque architecture on doit traverser une couche d'authentification nous allons ici proposer quelques solutions à mettre sur pied pour assurer la bonne gestion des accès

Authentification Forte : il faudra mettre sur pied:

- MFA (multi factor authentication) sur :
 - VPN
 - Comptes Administrateurs
 - Access Scada Cloud
- Politique de Mot de Passe forte(minimum 10 caractères composés de lettre chiffre, minuscule, majuscule,caractères spéciaux)
- Rotation régulière des identifiants

tout cela permettra de réduire le risque de compromission après phishing

3-Sécurisation du vpn et Accès distant

Pour ce qui est la sécurisation des du vpn nous avons plusieurs actions a recommander

- Restreindre l'accès VPN par liste blanche d'IP
- Utiliser les certificats clients
- Journalisées toutes les connexions
- Limiter les accès aux seuls ressources nécessaires

Ceci permettra d'avoir un strict contrôle des accès distants

4- Protection des systèmes industriels (IOT)

Nous savons que les architectures IOT sont critiques, les mesures à mettre en place sont les suivantes

- Désactiver les services inutiles
- Mettre à jours les firmwares
- Surveiller les communications ModBus
- isoler les **PLC Siemens** dans un VLAN dédié

Toutes ces mesures seront mises en place pour la prévention contre les sabotage industriels

5. Sécurité du cloud SCADA

Mesures essentielles :

- chiffrement **TLS obligatoire**
- authentification forte
- journalisation des accès
- surveillance des API REST
- sauvegarde régulière des données de supervision

Cela permettra la réduction du risque de compromission du système de supervision.

6. Protection contre les attaques informatiques

Ici il y aura plusieurs solutions à mettre en place

- **SIEM** (collecte des logs)
- **IDS / IPS réseau**
- surveillance des anomalies de trafic

Sources de logs :

- pare-feu
- VPN
- serveurs
- SCADA
- contrôleurs d'accès

8. Sécurité des objets connectés et caméras

Pour les objets connectés comme mesures de sécurités nous pouvons :

- changer les mots de passe par défaut
- isoler les caméras dans un réseau dédié
- désactiver SNMP non sécurisé
- mettre à jour les firmwares
- chiffrer les flux vidéo si possible

Bénéfice :

- empêche l'exploitation des IoT comme point d'entrée.

1. Mesures techniques

Authentification

- l'authentification multi-facteur (MFA) pour les VPN et les comptes administrateur .
- Gestion des accès privilégiés (PAM)

Chiffrement

- ❖ HTTPS obligatoire
- ❖ MQTT sécurisé (MQTTS)
- ❖ VPN IPsec .

Supervision

Mise en place d'un siem (wazuh) .

collecte les log :

- logs serveurs
- logs firewall
- logs AD

Détection

Utilisation de Sigma rules .

ex : détection d'accès anormal sur RDP .

Sauvegarde

stratégie 3-2-1

- 3 copies
- 2 supports différents
- 1 hors ligne(air - gap) .

